



Islington college
(इस्लिंग्टन कलेज)

Legal & Ethical Considerations Report
Project Title: Intelligence Recon System

Student Name: Prabesh Sundar Taksari

LMU ID: 23047464

1. Introduction

In this report, the legal and ethical issues associated with the creation and implementation of an AI-Powered Vulnerability Assessment Tool are described. The project will help cybersecurity-related professionals to detect and evaluate the vulnerability of web apps and networked systems and maintain adherence to the Electronic Transactions Act, 2063 of Nepal, the Privacy Act, 2075, the General Data Protection Regulation (GDPR), the ISO/IEC 27001 Information Security Management standards and OWASP Top 10 model of security.

2. Legal Consideration

2.1. Nepal's Electronic Transactions Act, 2063 (2006)

Nepal's Electronic Transactions Act, 2063 governs electronic transactions and cybercrime within Nepal. The Vulnerability Assessment Tool should meet the following provisions:

- 1. Prohibition of Unauthorized Access:** The user must not apply the tool to systems not owned by the user or without a written agreement to do so on the provisions of the Act on unauthorized access to computer systems (Nepal, 2025).
- 2. Mandatory Authorization Agreement:** Terms of Service will be presented to the user's authorizing use of the service, and they will be obligated to agree to this before starting any scan (Nepal, 2025).
- 3. Cybercrime Prevention:** The site will be structured in a way that would stop its misuse that may amount to cybercrime under the Act such as hacking into the system to obtain illegal access to electronic records (Nepal, 2025).

2.2. General Data Protection Regulation (GDPR)

The GDPR (EU Regulation 2016/679) provides rigid data protection and privacy conditions to the management of personal data. The Vulnerability Assessment Tool should meet the following principles of GDPR:

- 1. Lawfulness, Fairness, and Transparency:** The users should be told how their scan data and results are stored, processed and accessed (EUR-Lex, 2016).
- 2. Minimization of Data:** "Essential data that is necessary to perform scanning operations and any data that is not necessary should not be stored or should not be collected as unnecessary personal identifiable information (EUR-Lex, 2016).

3. **Right to Access and Erasure:** The users must be able to access and edit as well as permanently delete the scan information stored about them when requested (Article 17 - Right to be Forgotten) (EUR-Lex, 2016).
4. **Data Breach Notification:** The security breaches of user data should be notified to the authorities and to the affected users within 72 hours (Article 33) (EUR-Lex, 2016).
5. **Encryption & Security Controls:** To avoid unauthorized access to user data and scan results, all user data and scan results should be stored with the help of industry-standard encryption (EUR-Lex, 2016).

2.3. Nepal's Privacy Act, 2075 (2018)

In Nepal, the Privacy Act, 2075 provides the right of any individual to the privacy of their personal data. The Vulnerability Assessment Tool must comply with the following principles:

1. **Consent-Based Data Collection:** The personal data will be collected only with the informed consent of the user in accordance with the requirements of the Act (Nepal, 2018).
2. **Purpose Limitation:** Any data obtained will be utilized only with the intent in which it was obtained and will not be re-utilized without permission (Nepal, 2018).
3. **Data Security Obligations:** There will be effective security measures against unauthorized access, use, alteration, or disclosure of personal data (Nepal, 2018).
4. **Right to Erasure:** At any point, the users will be entitled to demand the removal of their personal data on the platform (Nepal, 2018).

2.4. Information Security Management ISO/IEC 27001.

The ISO/IEC 27001 is a standard that is universally acceptable in securing the best practice of managing information. The Vulnerability Assessment Tool will be consistent with the following security measures:

1. **Policy on access control:** It is necessary to provide access to scanned data and results of the users only (Nduhiu, 2025).
2. **Confidentiality, Integrity and Availability (CIA Triad):** The security measures, such as encryption, secure backups, and availability guarantees, are implemented (Nduhiu, 2025).
3. **Periodic Security Audits:** The vulnerability assessments and code reviews are to be performed to detect risks within the platform itself (Nduhiu, 2025).
4. **Incident Response Plan:** This is putting up protocols for security incidents such as detection, containment, and mitigation strategies (Nduhiu, 2025).

3. Ethical Considerations

3.1. User Confidence and Trust.

Sensitive scan data and target information will be left to the Vulnerability Assessment Tool by users. The ethical considerations that will be considered during development will include the following:

1. **Clear Policies:** Before using the platform, users will be informed of the way their scanning and results are stored, processed, and secured (Akitra, 2024).
2. **Ownership of Data:** The users will be designed to be the owners of their scanned data and will be allowed to export or delete the scanned data any time they want (Akitra, 2024).
3. **No Data Monetization:** The user information and scan data will not be sold or utilized to conduct advertisements or any other commercial activity, other than offering the service (Akitra, 2024).

3.2. Avoiding Misuse and Dual-Use Risk.

Tools used in vulnerability assessment have dual-use risk as it is implicit in the nature of the tools being used to assist defenders that could equally be used by attackers. To reduce this risk, the following measures are going to be planned:

1. **Acceptable Use Policy:** An elaborate Acceptable Use Policy (AUP) will be formulated and handed over to all users at the time of registration, which categorically forbids the use of the tool to conduct unauthorized scanning, offensive attacks, or any other activity that is against the law (Akitra, 2024).
2. **Rate Limiting and Scope Controls:** Technical controls will be designed and executed to curb aggressive or abusive scanning traffic that may lead to disruption of target systems even when allowed to be tested (Akitra, 2024).
3. **AI Decision Transparency:** The AI part of the system, as the decision-making tool and scanning plans, is going to be structured to generate explainable outputs that users can understand what is being done on their behalf to avoid making the AI a black box (Akitra, 2024).

4. References

Akitra, 2024. *Akitra*. [Online]
Available at: <https://akitra.com/blog/explainable-ai-xai-in-cybersecurity/>
[Accessed 04 April 2026].

EUR-Lex, 2016. *EUR-Lex*. [Online]
Available at: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
[Accessed 03 April 2026].

Nduhiu, J., 2025. *Splunk*. [Online]
Available at: https://www.splunk.com/en_us/blog/learn/iso-iec-27001.html
[Accessed 04 April 2026].

Nepal, F. P. o., 2018. *The Privacy Act, 2075 (2018)*, Kathmandu: Nepal Law Commission .

Nepal, N., 2025. *Notary Nepal*. [Online]
Available at: <https://notarynepal.com/blog/electronic-transaction-act-nepal>
[Accessed 04 April 2026].